

# Your Turn: Design a Secure Workflow

Secure AI Workshop — Building a Secure Internal AI System for Higher Education

Group / Team: \_\_\_\_\_ Members: \_\_\_\_\_

**How this works.** In your group, apply the seven-layer architecture and the 70% confidence threshold to a real academic scenario. Pick a scenario, assess its risks, configure four key layers, and design the human checkpoint. Aim for *defensible, not perfect* — you will defend your design at the end.

## ACTIVITY · STEP ZERO

### Choose your scenario

Pick **one** as a group — you'll design and defend it.

#### ☐ Scenario A

#### AI-Assisted Grading System

Generates feedback and suggested scores for student essays.

#### ☐ Scenario B

#### IP-Protected Research Assistant

Summarizes unpublished manuscripts and identifies research gaps.

## ACTIVITY · STEP 1 · RISK

### Name two critical risks of using public AI 5 min

If your group ran this scenario on public ChatGPT instead of an internal system, what could go wrong? Give a concrete example for each.

**Risk 1 — Data privacy & IP:** *what could leak?*

**Risk 2 — Integrity & accuracy:** *where do hallucinations hurt?*

## ACTIVITY · STEP 2 · CONFIGURE FOUR LAYERS

### Apply the architecture 15 min

*Be concrete — name real systems and real data sources.*

**L1 • Access** *Who may use it, and what are their limits?*

---

**L3 • Input Safety** *Which PII or keywords must be redacted?*

---

**L4 • RAG** *Which institutional sources will ground it?*

---

**L6 • Output Control** *How do you verify against the sources?*

---

ACTIVITY • STEP 3

**Design the human checkpoint** 10 min

THE 62% TEST

**Your AI returns a result at 62% confidence.**

It's below the 70% threshold. Map the exact steps the faculty reviewer takes before it reaches the end user.

GUARD THE REVIEWER

**Now keep that reviewer from burning out.**

Spell out your fatigue strategy — rotation, escalation, and what you deliberately choose not to review.

**Reviewer's steps for the 62% result:**

---

**Fatigue-mitigation strategy:**

---

ACTIVITY · EVALUATION

# Evaluate your design

Total \_\_\_\_ / 20

Use these as a checklist while you design — not just at the end. Score each criterion out of 5.

| CRITERION            | PROFICIENT · 3–4                                   | EXEMPLARY · 5                                               | SCORE    |
|----------------------|----------------------------------------------------|-------------------------------------------------------------|----------|
| Security & Privacy   | Basic PII filters and user roles identified.       | Full Layer-3 sanitization and local-first data sovereignty. | ____ / 5 |
| Grounding & Accuracy | Uses RAG, but sources are loosely defined.         | Layer-4 RAG with citations and Layer-6 consistency checks.  | ____ / 5 |
| HITL Effectiveness   | A review process exists, but triggers are unclear. | Clear 70% threshold with a fatigue-mitigation strategy.     | ____ / 5 |
| Institutional Value  | Addresses a need, but ignores infrastructure cost. | Balances operational complexity against clear benefits.     | ____ / 5 |

PRESENT · DISCUSSION

## Defend your design (2 minutes)

- Which scenario did you choose, and what was its single biggest risk?
- Which one layer did the most work to make it safe?
- Walk us through what happens to a 62% result.
- What did you deliberately choose NOT to review — and why is that safe?

Notes from discussion:

**Optional hands-on lab.** Want to run this design instead of just sketching it? Open the “Notebooks” folder (00–04) and run the secure pipeline yourself — PII redaction, RAG grounding, and the 70% threshold, all offline with no API key needed.

*Bring AI inside the walls — controlled, grounded, and human-supervised.*

A conceptual framework, not a finished product — the real test is the pilot. · Nguyen Thanh Tuan · nttuan@vku.udn.vn · Vietnam–Korea University of ICT, University of Danang